

SEE ALSO Newsletter of March 7, 2024

[doc. web n. 9991183]

Provision of February 8, 2024

Register of provisions

n. 62 of February 8, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by

Prof. Pasquale Stazione, president, Prof.

Ginevra Cerrina Feroni, vice president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Dr. Claudio Filippi, deputy secretary general;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament

and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to

the processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003,

containing the "Code regarding the protection of personal data"

(hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning

internal procedures of external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of April 4, 2019, published in

G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web

n. 9107633 (hereinafter "Guarantor Regulation No.

1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the deputy secretary

general pursuant to Article 15 of the Guarantor Regulation

No. 1/2000 on the organization and

functioning of the office of the Guarantor for the

protection of personal data, doc. web n. 1098801;

Rapporteur Attorney Guido Scorza;

PREAMBLE

1. The violation of personal data

The company Medtronic Italia (hereinafter "Company"),

by act of XX, subsequently supplemented by

communication of XX, notified the Authority of a

personal data breach, pursuant to Article 33

of Regulation (EU) 2016/679 of the European Parliament

and of the Council of April 27, 2016 (hereinafter

"Regulation").

In relation to this event, the Company communicated

that: "On XX at approximately 15:30, a member of the Medtronic Diabetes team sent an email notification

to users of the MiniMed Mobile app located in various

countries inside and outside the EU to

inform them about (1) a server maintenance update

and (2) the requirement for users to log back into

the CareLink™ Personal software, as part of this server maintenance update. A total of 11 email notifications were sent using Microsoft Outlook, as a temporary solution pending the implementation of a new automated process. 10 email notifications contained between 490 and 495 email addresses, while 1 email notification contained 8 email addresses. Based on the investigation conducted to date, the Diabetes team member did not follow the process defined by Medtronic for planned and unplanned server outages, and included the email addresses of the recipients in the “To” field, instead of in the “BCC” field. Due to this human error, the email addresses of the recipients were visible to other recipients, namely approximately 489-494 recipients or 7 recipients, depending on the email sent. Approximately 5,001 email addresses of MiniMed Mobile app users worldwide were exposed, of which 732 were in Italy. The content of the email notification did not include any personal data so that only the email addresses were visible to other recipients. Immediately after becoming aware of the issue, Medtronic took measures to remedy the problem and prevent it from recurring. An immediate attempt was made to recall all emails and an email was sent to all affected users asking them to delete any copy of the email received on XX. Medtronic retrained the relevant staff to remind them of the importance of following standard email notification processes and is about to implement a new automated tool to prevent this from happening in the future.”

More specifically, it was stated that “the reported incident involves the possibility for unauthorized third parties to access email addresses of individuals potentially interested in diabetes products, namely the email addresses of their caretakers. Such email addresses are in some cases composed of a combination of first and last names, which makes it possible to identify the individual in question, indirectly disclosing data related to their health, namely a special category of personal data pursuant to Article 9 of the GDPR” and that “only the email addresses were visible to the other recipients of the email. The content of the email did not include any personal data but reveals that the recipients are users of the MiniMed Mobile app and therefore individuals who may be affected by diabetes.”

Regarding the likely consequences, it was assessed that “the incident could lead to phishing attempts. However, Medtronic has taken measures to recall the emails and has asked all users to delete any copy of the email received so that Medtronic can reasonably expect that such users will comply with Medtronic's instructions and not take further action with such information.”

Furthermore, the Company stated that it has “a rigorous procedure for planned

and unplanned server outages with various

Steps to follow to inform users.

However, Medtronic's standard procedure has not been followed in the case at hand. Furthermore, Medtronic is reviewing its current processes to further improve them, using a new automated tool to prevent this incident from occurring in the future.

The Company has also stated that:

- to remedy the violation and reduce its negative effects on the affected parties, "immediately after discovering this issue, Medtronic undertook a series of corrective actions, including (1) recalling the emails; (2) instructing the email recipients to (i) delete any copies of the email received with the email addresses of the recipients in the "to" field and (ii) not to take any further action with such information; and (3) retraining the relevant staff";
- to prevent similar future violations "it is reviewing its processes to further improve them (for example, by implementing additional checks before sending any email notifications). Medtronic is also implementing a new tool to prevent this from happening in the future";
- "the same violation is reported by other subsidiaries of the Medtronic group, each as a data controller, to the competent data protection authorities in Belgium, the Czech Republic, Finland, Germany, the Netherlands, Norway, Spain, Sweden, France, and the United Kingdom".

2. The Investigative Activity

With specific reference to the facts subject to the aforementioned violation, the Company, in a note dated XX, responded to the request for information from the Office of XX (prot. no. XX). In this context, in addition to what has already been communicated, the Company, representing that it is part of the "Medtronic group, whose operational headquarters is located in the United States" and that "the Medtronic group is a global leader in the development and production of medical devices for the care and treatment of various diseases, including diabetes," stated that:

- "the MiniMed™ Mobile app is a Medtronic app that connects - via Bluetooth - the MiniMed™ insulin pump to the user's smartphone, allowing the user to view pump and sensor information on their smartphone. The MiniMed™ Mobile app requires registration with CareLink™ Personal, a software classified as a medical device (...);
- "once a CareLink™ Personal account is created and registration is completed, the MiniMed™ Mobile app receives data from the user's MiniMed™ insulin pump and can be, at the user's discretion, manually or automatically synchronized with the user's CareLink™ Personal account (...)" which aims to "provide a secondary view on the user's smartphone, for self-monitoring by the user and to synchronize data with CareLink™ Personal";
- "the processing of users' personal data through CareLink™ Personal and the related MiniMed Mobile app is described in a specific privacy notice (...). Since this is a special category of personal data (health data), explicit consent from users is required for the provision of services, including sending users operational communications, such as server maintenance updates";
- "the notice is shown for the first time to users, and consent is given by them, at the time of registration on CareLink™ Personal before users provide personal data" and it is "always ensured that users can modify or revoke their consent at any time by accessing their personal account (...);
- "the MiniMed™ Mobile app is available in various countries. In each country, the Medtronic group company established there is responsible for providing technical assistance and support to users of the MiniMed™ Mobile app residing in the country where that company is established, including sending related communications. Consequently, the writing Company acts as the data controller of the personal data of users of the MiniMed™ Mobile app located in Italy (...);
- "within the Medtronic group, (...) [the Company] uses centralized helpdesk functions to provide technical assistance and support services. (...) provided by Medtronic MiniMed, Inc. Among these services is the provision by Medtronic MiniMed, Inc. of second and third-level technical assistance and support for issues that cannot be resolved locally, as well as for sending urgent service interruption communications, such as that subject to the violation notification";
- "Medtronic MiniMed, Inc. provides such services (...) as a data processor while each of those subsidiaries (including the writing Company) acts as an independent data controller of the personal data of users of the MiniMed™ Mobile app located in their respective country".

With particular reference to the cross-border nature of the processing, the Company has represented that:

- it and, more generally, the Medtronic group, do not have a “main establishment within the meaning of Article 4, paragraph 16, of the Regulation. The Company acts solely as a controller in relation to the processing of personal data of users of the MiniMed™ Mobile app in Italy” and “has not processed the personal data of individuals located outside the Italian territory, neither on its own behalf nor on behalf of other subsidiaries of the Medtronic group established in other EU member states”;
- “the subsidiaries of the Medtronic group established in the territory of the EU make autonomous decisions regarding the purposes and means of processing the personal data of users of the MiniMed™ Mobile app in their country”;
- “in the case at hand, however, since the email communication in question had to be sent urgently, the writing Company (as well as the other EU subsidiaries) made use of the services of the technical support team available 24 hours a day provided by Medtronic MiniMed, Inc. to send the communication”;
- “(...) did not process personal data of individuals located outside the territory of Italy, neither on its own behalf nor on behalf of other subsidiaries of the Medtronic Group in the EU.” In relation to the legal basis on which the personal data of the data subjects were processed and which would have allowed the sending of the email to them, the Company clarified that “explicit consent was requested from users for the processing of their personal data for the provision of services, including the sending of related operational communications, in accordance with Article 6, paragraph 1, letter a), and Article 9, paragraph 2, letter a), of the Regulation” and that “where the Privacy Notice refers to the use of consent for other purposes, separate and specific explicit consent is requested for such purposes, such as the improvement and development of products and services and the overall enhancement of therapy management and the development of publications and marketing materials.” Regarding the intra-group data transfer, the Company highlighted that “for the performance of technical assistance and support activities, it is necessary for certain personal data to be transferred to the U.S. company Medtronic MiniMed” and that “in accordance with current regulations, new Standard Contractual Clauses based on the Commission Implementing Decision (EU) 2021/914 have recently been signed.” In any case, “the 24-hour technical support team of Medtronic, which actually sent the communications in question, is located in Canada, recognized by the European Commission as a country that ensures an adequate level of data protection (according to the Commission's decision of December 20, 2001).” The Canadian staff of the 24-hour technical support team of Medtronic received specific training on the procedure in January 2021, that is, before the reported breach. In order to prevent the recurrence of similar events, the Company stated that it has conducted training for the “relevant staff to emphasize the importance of following standard business processes for sending notifications to users and to reiterate the need to include recipients in the “BCC” field” and that it has “implemented a peer-review process so that all notifications sent to users of the MiniMed™ Mobile app are double-checked by a second designated employee, to ensure that recipients have been included only in the “BCC” field, attaching documentation that certifies the implementation of this new process and that “a new solution for sending notifications to users is being implemented, in order to reduce the manual steps involved in the process, which are usually performed by staff. This involves automating the process to include recipients in the “BCC” field, reducing the risk of unauthorized disclosure of personal data caused by human errors when sending notifications to users of the MiniMed™ Mobile app.” With a subsequent note dated XX, the Company responded to the further request for information from the Authority (note dated XX, prot. no. XX) concerning, in particular, the profiles of personal data protection carried out by the figures of the “Doctor” and the “Medical Center” mentioned in the privacy notice regarding the processing of personal data acquired in the course of the proceedings. In particular, with reference to the CareLink™ Personal system, which is the subject of these proceedings, the Company clarified that: it is a medical device “consisting of a free web-based application intended directly for individuals with diabetes who use compatible Medtronic medical devices (“Device Users”) and for the people who assist them (“Care Partners” - a Care Partner is any person providing assistance (family member, friend, etc.) who has received authorization from an individual with diabetes to view their diabetes information on a secondary access on CareLink™ Personal) (collectively, “CareLink™ Personal

Users”);

“CareLink™ Personal Users can independently register by creating their own CareLink™ Personal account and accessing the Device User data uploaded to CareLink™ Personal (via an uploader accessed from the web platform or, for compatible devices, via the MiniMed™ Mobile app) to help them manage their condition”;

“in 2020, during the Covid-19 pandemic, (...) the additional and optional feature available through CareLink™ Personal called “Health Partner Share” (“HPS”) was activated in Italy. The HPS function allows Device Users, who expressly and specifically consent, to share only with their Healthcare Professional the device data uploaded to their CareLink™ Personal account”;

“data sharing is only possible if the Healthcare Professional has created an individual account through CareLink™ Personal”;

“the HPS function is completely optional as Device Users can fully utilize the CareLink™ Personal account to support the own credentials)”. In the second case, “the Professional Healthcare Provider sends an invitation to the User of the device through CareLink™ Personal, which the User can accept to establish the connection between their account and the Professional Healthcare Provider’s account.”

The Company has also clarified that the connection of the Professional Healthcare Provider’s HPS account with the User’s account is subject to the User’s explicit consent, which is a requirement integrated into the CareLink™ Personal software. In this context, “the Professional Healthcare Provider is an independent data controller for the further processing of data on CareLink™ Personal for medical care purposes. As such, the Professional Healthcare Provider is responsible for complying with applicable transparency obligations towards their patients, with whom the Professional Healthcare Provider has a pre-existing doctor/patient relationship aimed at providing medical care services.” Therefore, it would be the users who choose whether to allow the connection of their account and thus share data with healthcare professionals.

Finally, the Company described the processes for registering the CareLink™ Personal account and the Healthcare Provider who intends to use the HPS functionality, as well as the process of associating the doctor’s account with that of their patient. In this regard, it was specified that this connection can occur in two ways: during the patient’s visit to the healthcare provider’s office or “via an invitation generated through CareLink™ Personal.” In the first case, “the Healthcare Provider, who has previously created their account in CareLink™ Personal, accesses their account (...) enters the name and date of birth of their patient to create the patient’s profile in the Healthcare Provider’s account (...) selects ‘Connect now using the patient’s username and password (the patient is present and enters their own credentials)’.”

credentials to link accounts)”. At this point “the Healthcare Professional is redirected to a page intended for their patients (...) will read the text that appears on that page to their patient, before asking the patient to enter their CareLink™ Personal credentials on this same page. By entering their CareLink™ Personal credentials, the patient gives express consent to activate the link; once the credentials are correctly entered, the patient’s CareLink™ Personal account and the Healthcare Professional’s HPS account are linked, and the patient’s device data can be shared with the Healthcare Professional”.

In the case of remote linking “(...) the patient must provide their CareLink™ Personal username to the Healthcare Professional” who “creates an account and the profile of a patient in their HPS account; or the Healthcare Professional selects “Send a link request using the patient’s username (the patient will confirm the request from their CareLink™ Personal account)”;

or the Healthcare Professional receives a text, which must be read before entering the patient’s CareLink™ Personal username in CareLink™ Personal and clicking “Link”; or the patient will then receive an email at the email address associated with their CareLink™ Personal username, as well as a notification on their CareLink™ Personal account; the patient must log into their CareLink™ Personal account (a link to the CareLink™ Personal web page is included in the email) to access the link request sent by the Healthcare Professional; or to complete the linking, the patient must read the text before accepting the link request; or once

acceptance is provided, the device data uploaded in the patient's CareLink™ Personal can be viewed by the Healthcare Professional”.

In both cases, the linking between the two accounts is only possible (1) following a specific assessment on the matter between the Healthcare Professional and the patient, and (2) after the patient has actively provided the relevant information to enable the Company to facilitate the linking.

In relation to these aspects, the privacy notice acquired in the proceedings specifies that: “If you choose to share personal data with healthcare providers in the context of medical treatment or with other parties outside Medtronic, they will be solely responsible for the use, or further processing, of the personal data” (p. 2 “Privacy Notice”, Annex A to the note of XX).

Based on what was represented by the data controller in the notification of the breach and in the notes with which it responded to the requests for information, as well as subsequent evaluations carried out, the Office, by act of XX (prot. n. XX), notified on the same date via certified email, which must be understood as fully reproduced here, initiated, pursuant to Article 166, paragraph 5, of the Code, with reference to the specific situations of illegality mentioned therein, a procedure for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, against the Company inviting it to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

With the aforementioned act, the Office noted that the Company, in relation to the breach of personal data, communicated health-related data of approximately 732 Italian subjects to an equal number of subjects, in the absence of a suitable legal basis and, therefore, in violation of the applicable principles for the processing of personal data, as per Articles 5, paragraph 1, letters a) and f) and 9 of the Regulation and in the absence of adequate security measures, in violation of Article 32 of the Regulation; regarding the processing of personal data carried out by the Company during the registration process of the CareLink™ Personal account and that of the Healthcare Professional intending to use the HPS functionality as well as the process of associating the doctor's account with that of their patient, the Company failed to provide patients with the informative element regarding the legal basis under which the aforementioned communication of personal data is made, which constitutes a new operation of processing personal data, including health data by healthcare professionals, as autonomous data controllers; this in violation of the aforementioned principles of fairness and transparency as per Articles 5, paragraph 1, letter a), and Articles 12 and 13 of the Regulation, as well as Articles 7 and 9 of the Regulation, since the aforementioned omission would have affected the validity of the consent possibly given by the patient.

3. Defensive Memoranda

By note of XX (prot. n. XX), the Company submitted its defensive memoranda, pursuant to Article 166, paragraph 6, of the Code without requesting to be heard, also providing the elements referred to in Article 83, paragraph 2, of the Regulation, in which it was particularly represented as follows.

3.1. The breach of personal data pursuant to Article 33 of the Regulation

The Company, in relation to the breach of personal data, notified to the Authority, pursuant to Article 33 of the Regulation, stated that:

- “the processing of personal data of users of the CareLink™ Personal software is based on their explicit consent (...). All users of the MiniMed™ Mobile app have voluntarily downloaded the app after being fully informed”.

“information on the terms of use and the characteristics of the processing of their personal data”;

- “it is obvious that the accidental disclosure 'in plain text' of users' email addresses to other users of the service, which occurred on XX, was entirely due to an unintentional human error, committed in violation of the technical and organizational measures put in place by Medtronic for the protection of users' personal data. It is necessary to differentiate the liability profile of the entity, Medtronic, which has diligently implemented technical and organizational measures and has promptly reported their violation (...) to the Authority, from that of those who violated them, even if by mistake”;

- "the erroneous communication in question occurred under extraordinary circumstances of urgency (and certainly not for promotional purposes or for other benefits of Medtronic) due to the need to promptly inform users that the MiniMed™ Mobile app would be subject to certain unplanned maintenance interventions on the systems. One must not forget that diabetic patients 'live' on data: knowing their glycemic levels over 24 hours is vital for them, and after a patient has consented to use the MiniMed™ Mobile app, it is imperative to inform them of any connection issues";
- "such error occurred (...) in violation of a specific procedure that had been adopted by Medtronic precisely to prevent situations like the one subject to the current proceedings. Moreover, this procedure had been the subject of specific training activities for employees and collaborators. In fact: Medtronic adopted a specific procedure (...) aimed at regulating the preparation and sending of communications to users in the event of unplanned maintenance interventions, which expressly provides that the email addresses of the users receiving the communication must be inserted in the blind carbon copy ('BCC') field and not in the recipients ('To') field, and that each communication must be reviewed by a responsible person from the technical support division before being sent; this procedure was disseminated and training was directed to the members of the Medtronic Diabetes team responsible for sending communications to users (...); it is emphasized that this training took place before the identified violation; more generally, Medtronic has adopted a series of technical and organizational measures (...) aimed, among other things, at managing access by all authorized personnel, preventing unauthorized access, adopting all necessary IT and physical security measures on the systems, etc.";
- "the tool of sending communications to users via email is the most suitable technical solution for managing communications to users in the event of urgent and unplanned interventions on the systems; in such cases, in fact, Medtronic may find itself needing to send alerts to users within very short timeframes, and the email communication tool can be activated very quickly; the MiniMed™ Mobile app does not currently provide alternative functionalities for sending communications to users in emergency situations. Furthermore, the MiniMed™ Mobile app is part of the CareLink™ Personal software, a medical device with CE marking subject to a certification process and not freely modifiable by Medtronic at its discretion, which stipulates that notifications to users must be sent exclusively via email; and a human error such as the one that occurred was not foreseeable, nor otherwise avoidable. As recognized by the EDPB, despite the adoption of technical and organizational measures, 'it is very difficult for data controllers (...) to adopt measures to prevent [personal data breaches due to human error]'";
- "while it is undeniable (and indeed has been voluntarily acknowledged by Medtronic) that there was a data breach, it should not be forgotten that this data breach did not occur in a vacuum of technical and organizational measures, which, rather, had proven adequate up to that point";
- "subsequent to the event that occurred, Medtronic has adopted a series of remedial actions, including: (i) the immediate attempt to recall all sent email messages; (ii) the sending of a message to all recipients, requesting them to delete the previously received message and not to process any data regarding the erroneously communicated information (...); (iii) the affected personnel underwent new targeted training to prevent the recurrence of similar events (...); (iv) a new automated tool has been implemented to assist the process of communication to users, which will require Medtronic Diabetes personnel to upload users' email addresses to a dedicated platform and will minimize the possibility of human errors in sending emails to recipients, who will always be in blind carbon copy";
- "the concrete consequences, if any, resulting from the error in sending the communication to users, appear to be particularly limited. In fact: only the email addresses of users were communicated, while no other personal data, nor specific health data or health-related information of users was communicated; only in some cases and only indirectly could the email addresses lead to the identification of a specific user: in many cases, in fact, a user's email address does not reflect the patient's first and last name; similarly, many email addresses could belong to individuals who are not patients, but..."

simply to subjects who provide assistance to patients (whose health data has not been disclosed); Medtronic has not received any reports or claims for compensation from users affected by the erroneous communication a year and a half later."

3.2 Further Disputes

With specific reference to the further violations contested in the proceedings initiated pursuant to Article 166, paragraph 5, of the Code, the Company, in relation to the functionality known as Health Partner Share (“HPS”), implemented during the pandemic period, which allows the patient to connect their CareLink™ Personal account with that of the healthcare professional treating them, stated that:

- “Medtronic has provided clear information regarding the processing subject to this dispute, which – it is useful to clarify – consists solely of the connection between the user’s account and that of their healthcare professional (and certainly does not extend to any further processing activities carried out by the healthcare professional, as an independent data controller). In fact, (...) firstly, there are references to the connection of accounts, and to the corresponding sharing of device data with healthcare professionals, both in the information provided in September 2020 (see page 3 of Annex A to our communication of XX) and in the subsequent information of 2022 (see page 2 of Annex A to our communication of XX), and secondly, there is the specific and detailed information provided to the user at the time consent is requested to establish the connection with the treating physician’s account”;
- “the information provided to the patient during the connection of their CareLink™ Personal account with the healthcare professional’s CareLink™ HPS account meets the minimum content requirements for the consent to be ‘informed’;
- “specific, exhaustive, and adequate information is provided to the patient at the time their consent is requested to connect their CareLink™ Personal account with the HPS account of the healthcare professional. The process of connecting the patient’s CareLink™ Personal account with the healthcare professional’s HPS account was described in Medtronic’s note of XX, but it may be useful to reiterate how this process works and to describe in more detail the content of the consent form presented to the patient at the time of connection. As illustrated, the connection can be established in two ways: (a) during the patient’s visit to their healthcare professional’s office, or (b) remotely, via an invitation generated through CareLink™ Personal”;
- when describing the connection process during the patient’s visit to their treating physician: “The patient (user of CareLink™ Personal) goes to their treating physician’s office. The physician – who has previously created their account in CareLink™ Personal – accesses their account. The healthcare professional enters the name and date of birth of their patient to create the patient profile in the healthcare professional’s account. The healthcare professional selects ‘Connect patient profile to CareLink™ Personal’ and ‘Connect now using the patient’s username and password.’ Subsequently, the healthcare professional is redirected to a page intended for their patient. In practice, the healthcare professional will read the notice that appears on the page intended for the patient before asking the patient to enter their CareLink™ Personal credentials on the same page. By entering their CareLink™ Personal credentials and clicking the ‘Connect’ button, the patient gives their explicit consent for the activation of the connection. The notice that appears on the page intended for the patient is as follows”: “Connecting the patient profile to the CareLink™ Personal of their healthcare professional: Connecting their CareLink™ Personal account to the patient record in the software CareLink™ account of their healthcare professional. By selecting the ‘Connect’ button, as the owner of the CareLink™ Personal account, you give your explicit consent to authorize Medtronic to connect your CareLink™ Personal account to the software CareLink™ account of your healthcare professional, so that the latter can view the data of the devices uploaded in CareLink™ Personal. You can revoke your consent by going to CareLink™ Personal and removing the connection with your healthcare professional. For more information on how Medtronic processes your personal data, please consult our privacy notice https://carelink.medtronic.eu/crs/pow/3.7/media/hsp_privacy_policy_it.pdf. Please refer to your healthcare professional to learn how your CareLink™ Personal data is processed by your healthcare professional, including how your health data is processed. Enter your personal username and password to connect to CareLink™ Personal”;
- “in accordance with the EDPB Guidelines 05/2020 on consent, adopted on May 4, 2020, the notice above, read in conjunction with the information referred to therein, contains all the minimum information necessary for the patient’s consent to be ‘informed’, namely: the identity of both independent data controllers: Medtronic, on one side, which is identified in the aforementioned

information as the data controller for the creation of the CareLink™ Personal account.

the sharing of data with the specified healthcare professional. If you agree to the connection, please click "Accept" to proceed with linking your CareLink™ Personal account to the healthcare professional's account.

- "The patient, upon accepting the connection request, will receive a confirmation notification indicating that the accounts have been successfully linked. The healthcare professional will now have access to the patient's device data uploaded to the CareLink™ Personal account. The patient will also receive a notification confirming the successful connection."

- "In summary, the process of linking accounts involves the following steps:

1. The healthcare professional discusses the connection with the patient.
2. The patient provides their CareLink™ Personal username.
3. The healthcare professional sends a connection request.
4. The patient receives an email and notification about the request.
5. The patient logs into their CareLink™ Personal account to accept the request.
6. The accounts are linked, allowing data sharing."

- "It is important to note that the patient has the right to revoke consent at any time by disconnecting the accounts through their CareLink™ Personal account settings. The patient's decision to connect or disconnect their account will not affect their access to Medtronic Diabetes products and services." any further sharing of Your CareLink™ Personal data with the account of the relevant healthcare professional's CareLink™ software; however, this will not result in the removal of data already shared by You. By clicking "Approve," You authorize Medtronic to link Your CareLink™ Personal account to the CareLink™ software account of Your healthcare professional. For more information on how Medtronic processes Your personal data, please refer to our "Privacy Policy";

- even in this case, the preceding notice, read in conjunction with the referenced information, contains all the minimum information necessary for the patient's consent to be "informed": the identity of both independent data controllers: Medtronic, on one side, which is identified in the aforementioned information, and the healthcare professional, who receives the data and is identified in the same notice; it should be noted that the user clearly sees the name of their healthcare professional before consenting to link their CareLink™ Personal account to the healthcare professional's HPS account; the purpose of the processing operations for which consent is requested: to link the patient's CareLink™ Personal account with the healthcare professional's HPS account, so that the healthcare professional can see the device data uploaded to CareLink™ Personal; the types of data collected and used: the device data uploaded to CareLink™ Personal; and the existence of the right to withdraw consent: explicit reference is made to the patient's ability to disconnect at any time by withdrawing their consent;

- "in both cases, regardless of which linking process is followed (at the healthcare professional's office or remotely), the request for consent to share data is sufficiently explicit to make the patient-user aware, in clear and simple terms, that the legal basis for such processing is precisely consent";

- "the processing of data by Medtronic consists solely and exclusively of linking the patient's CareLink™ Personal account to the healthcare professional's HPS account and the consequent sharing of device data, with the patient's consent. After that, as a result of the sharing, (...) further processing of the data is carried out by a different controller (the healthcare professional), who will have full and exclusive responsibility for providing the necessary information to the patient regarding the processing of the patient's health data. In other words, the purposes of the processing carried out by Medtronic, legitimized by explicit consent, are only those of allowing such linking, and these are perfectly outlined by the information provided to the patient at the time of linking (where it states that "once the linking procedure is completed, your healthcare professional will be able to view the data collected from your connected medical devices that have been uploaded to your CareLink™ Personal account, even at times different from those of in-person visits with your healthcare professional."). It cannot be required of Medtronic, as an independent data controller, to inform the patient about the purposes underlying the data processing carried out by the healthcare professional (who acts as an

independent data controller);

- "the recipient of the shared personal data is not just any healthcare professional, but the healthcare professional who is already managing the therapy of the patient-user and who initiates the request to have their HPS account linked to the patient's CareLink™ Personal account. Therefore, this healthcare professional, in addition to being, as already mentioned, explicitly identified in the screen preceding the linking, is already well known to the patient as their treating physician. The use of the MiniMed™ Mobile app is, in fact, just the final phase of a long care process that begins with the diagnosis of diabetes and continues with the prescription of an insulin pump by the physician; moreover, as previously mentioned, the sharing of data with the healthcare professional usually occurs in their presence or, following a discussion with the healthcare professional regarding this matter, remotely. It is therefore reasonable to assume that the assigned healthcare professional, regarding the processing activities that pertain to them, has already provided adequate information to the patient at the time of the initial establishment of the care relationship, or that they intend to provide it at a later time, in accordance with and within the limits expressly provided by Article 14, paragraph 3 of the GDPR (which, in the case of a controller receiving personal data from subjects other than the data subject, allows for the possibility of providing the information at a later time)";

- "Medtronic, in providing the information related to the request for consent for the processing that pertains to it, cannot certainly replace the healthcare professional regarding the obligation to provide the information related to the processing of data established by the latter during the course of care. This would contradict the principle of accountability (Article 5, paragraph 2 of the GDPR) and the role of independent data controller held by the healthcare professional, which has never been called into question. Moreover, the details of the data processing carried out by the healthcare professional are not even known to Medtronic, as they are subject to professional secrecy."

- "It should be emphasized that only the data collected from the user's device (e.g., measurements and parameters recorded by the device itself) are shared with the user's healthcare professional following the connection of the user's CareLink™ Personal account with the healthcare professional's HPS account; no other data or information, such as data, notes, or information manually uploaded by the user to their CareLink™ Personal account, are shared with the healthcare professional.";

- "The fact that there is already an underlying professional relationship between the healthcare professional requesting the sharing and the patient-user consenting to it (which, once again, Medtronic assumes has been established in accordance with the necessary informational obligations), and that the processing carried out by Medtronic constitutes nothing more than a tool to further facilitate that pre-existing care relationship, would even exempt Medtronic from providing any type of information regarding such activity, as provided for by Article 13, paragraph 4 of the GDPR. The information of which (...) the Authority contests the absence is, in essence, already (or at least should already be) in the possession of the patient-user.";

- "The information provided to the user is not lacking with respect to (a) the 'legal basis on which the communication is based', (b) 'the identity of the data controller', and (c) 'the purposes of the processing' in that: without the patient's consent, no data sharing is possible. The HPS functionality concretely realizes the principle of 'empowerment' of the patient in managing their illness and their data, fully in line with the principles that inspire the GDPR, as well as contemporary medicine. The same HPS functionality has been designed based on this fundamental principle: the user is presented with simple and clear terms that their consent is necessary for data sharing and can be revoked at any time. The activation of the HPS functionality is conditioned on the user's consent, who decides how and with whom to share their data; Moreover, the legal basis for data sharing through the HPS functionality is made evident to the patient-user; the notice that appears before data sharing clarifies the identity of the new data controller in case the user opts for data sharing: it is, moreover, a subject already known to the user as their treating physician; as for the purposes of the processing, Medtronic informs the user in advance that consent to activate the HPS functionality allows the connection between the patient's CareLink™ Personal account and the healthcare professional's HPS account. Medtronic cannot provide information regarding the 'purposes of the processing for which the personal

data are intended' as they pertain to the autonomous decision of a different data controller, who bears the relevant informational obligations (Medtronic does not treat patients but markets medical devices for the treatment of diabetes). In light of the above, Medtronic believes that the patient's consent is informed and, therefore, valid."

Finally, the Company has provided a series of assessed useful elements, within those identified by Article 83, paragraph 2 of the Regulation, both in relation to the contestation of the personal data breach concerning the above-described communication of health data through the sending of emails in "carbon copy" to multiple recipients, and in relation to the contestation of the violation regarding informational obligations and the acquisition of the related consent.

In particular, regarding the first aspect, the Company has highlighted that:

- "The violation subject to notification by Medtronic is characterized by a low level of severity. The following elements are relevant in this regard: (...) the contested violation essentially stems from a single isolated event, attributable to a clear human error, which affected a limited number of subjects (namely the 732 recipients of the communication regarding unscheduled server maintenance), and which cannot be repeated, also considering the implementation of an automated procedure for urgent communications related to interruptions - maintenance; (...) the violation occurred in the context of a processing that, in addition to being expressly consented to by the data subjects, has the sole and exclusive purpose of informing and ensuring the safety of the patient, preventing any malfunctions of the CareLink™ Personal software, which could impact their health or therapy; the violation has not caused any damage to the affected data subjects, neither of a physical/material nature, nor of an immaterial or reputational nature. This is even more evident, considering that none of the subjects affected by the violation has filed any complaint, nor any contestation against Medtronic, nor has anyone taken action to request any compensation for damages.";

- "The contested violation is undoubtedly negligent and not intentional, as it is characterized by the absence of volition regarding the causation of the data breach. (...) the violation resulted from an unintentional human error, which occurred due to the failure of a member of the Medtronic Diabetes team to apply rules and procedures adopted by Medtronic precisely to prevent events like the one subject to contestation. Had this employee adhered to internal procedures, the violation would not have occurred. (...). Therefore, also pursuant to the provisions of the Guidelines on Sanctions ("Guidelines 01/2021 on examples regarding the notification of a personal data breach" adopted on December 14, 2021, by the European Data Protection Board), human error, failure to read and comply with existing procedures, as well as their non-application, are all symptoms of negligence by the individual operator (not Medtronic), which exclude the existence of any form of voluntariness";

- "it is entirely undeniable that Medtronic, acting diligently, took appropriate action immediately to mitigate, if not completely eliminate, the harmful effects resulting from the data breach. In fact, in addition to being able to immediately identify the breach that occurred, Medtronic has: promptly notified the breach to the Authority; immediately recalled the sent emails; sent, also promptly, to the recipients of the communication, a new message inviting them to (i) delete any copy of the received email, and (ii) not take any further action with the information contained therein; and subjected internal staff to new training sessions";

- "Medtronic has implemented a new automated system that minimizes the risk of error for the future. The new automated system, in fact, excludes the need for the operator to choose between a list of email addresses of recipients in plain text or in blind copy, automatically sending an email communication with recipients in blind copy";

- "from the measures adopted, it can be inferred that Medtronic acted immediately with great timeliness, responsibility, and transparency, doing everything in its power to correct its actions and indeed seeking in every way to eliminate any harmful effects, 'taking responsibility for correcting or limiting the impact of its actions'" (cf. Guidelines on Sanctions, Chapter III I. c) last paragraph);

- “in order to prevent events of the kind that occurred, Medtronic had previously drafted a specific internal procedure (...) aimed at detailing the procedure that must be followed by its employees and collaborators in cases where, for reasons of urgency, it is necessary to proceed with a communication to users regarding an unscheduled service interruption. This procedure has been duly disseminated, as proven by documentation, and all employees and collaborators have also undergone specific training courses”;
- “it is important to remember that Articles 25 and 32 of the GDPR, in imposing the adoption of appropriate technical and organizational measures, establish a ‘duty of means and not of result’ (see, on this point, Guidelines on Sanctions, Chapter III, I. d) third paragraph), with the consequence that the mere occurrence of a breach is not sufficient to deem the system of organizational measures inadequate; rather, the abstract adequacy of such measures must be analyzed to ensure an appropriate level of security relative to the risk: adequacy that, given the specificity of the internal procedures, the training on them, and the fact that human error occurred only once, cannot certainly be deemed nonexistent”;
- “Medtronic has made itself fully available to the Authority from the outset in order to remedy the breach, promptly providing, in a comprehensive and transparent manner, all the information that has been requested (...)”;
- “it is debatable whether the breach involved health-related data as defined by Article 9 of the GDPR, since the data breach only involved the email addresses of the recipients of the communication made visible to other recipients, which do not always allow for the identification of the data subject (not all addresses correspond to name.surname@), nor do they automatically allow for the association of the communication recipients (where identifiable) with patients suffering from diabetes, given that the email addresses could well refer to individuals other than the patient, such as caregivers or parents, in the case of minor users. No data directly related to health (such as information on users' blood sugar levels, clinical therapies, or the use of devices connected to CareLink™ Personal) has been disclosed or communicated to third parties”;
- “the breach was reported by Medtronic voluntarily and within the time limits set by Article 33 of the GDPR. It was therefore the writer herself who informed the Authority of the data breach, and although the submission of the related notification in the event of a data breach constitutes an independent legal obligation on the part of the data controller pursuant to the provisions of the GDPR, it certainly demonstrates Medtronic's full intention to make itself available to this Authority in order to collaborate in managing the consequences of the breach”;
- “the adoption, by Medtronic, of an ethical code and an organizational model pursuant to Legislative Decree 231/2001 aimed at preventing unlawful conduct in relation to personal data, as well as the ongoing training on both, must be considered as having independent mitigating value; the particular social value of the purposes related to the processing, and the corresponding absence of any advantage in favor of Medtronic as a consequence of the alleged breach. What is at stake, in fact, is a processing necessary solely and exclusively to ensure the highest degree of security in relation to the use of CareLink™ Personal (...), safeguarding the health of patients. All of this, to the exclusive and undeniable benefit of the data subject, given that Medtronic does not obtain any economic advantage from this data processing; it is specified that CareLink™ Personal is offered free of charge to users who are already users of a Medtronic device; the same violation has already been reported by the respective subsidiaries of Medtronic to the Data Protection Authorities of their respective countries of origin (Belgium, Czech Republic, Finland, Germany, Netherlands, Norway, Spain, Sweden, France, United Kingdom), and the same Authorities have concluded the investigation by archiving the report.

In relation to the second aspect, concerning the challenge of the violation regarding informational obligations and the acquisition of the relevant consent, the Company has highlighted that:

- “the purpose of the processing (...) consists in the possibility of creating a connection between the patient's account and that of their healthcare professional, as can be found at the link: <https://www.me>

medtronic.com/content/dam/medtronic-com/it-it/corporate/documents/Codice-Condotta-Compass-Bussola-12-2020.pdf allowing the user/patient subject to certain therapies (or their caregiver) to share, in a simple, quick, and direct manner, data related to their illness with the healthcare professional who is already responsible for managing the relevant therapy, thus allowing them to access the blood glucose data of their patient. Once again, the only purpose related to the processing in question is to facilitate the therapeutic pathway and to enhance the control of doctors over the therapies assigned to their patients. All of this, clearly, is subject to the consent of the relevant patient. Medtronic does not communicate any data to healthcare professionals who are not already the treating physicians of the users;

- the patient data would concern only the patient in question, and would be communicated only to their healthcare professional (who, moreover, having already taken care of the patient, is likely to already possess – or could obtain from elsewhere – the data subject to the communication);

- the alleged violation has not caused any damage to the affected individuals, neither of a physical/material nature, nor of an immaterial or reputational nature (on the contrary, it entails an undeniable clinical advantage). This is even more evident when considering that none of the patients using CareLink™ Personal has filed any complaint, nor any direct challenge against Medtronic regarding the HPS functionality, nor have they taken steps to request any compensation for damages. On the contrary, the processing in question has allowed for the optimization of therapeutic pathways related to the treatment of particularly debilitating diseases, such as diabetes, obtaining the favor (and consent) of the respective users;

- “(...), Medtronic regularly reviews and updates its communications and privacy notices. Although Medtronic believes that the consent of patients for the sharing of data with their healthcare professionals through the HPS functionality is sufficiently informed and valid, Medtronic has updated its privacy notice (July 2022 version) to further increase the level of transparency provided to users of CareLink™ Personal and to address any questions regarding this. As updated, the privacy notice explicitly refers to the legal basis (i.e., explicit consent) for the aforementioned data processing. The updated version of the privacy notice (...) within the paragraph titled “Consent (Explicit)”: states the following “Processing of health data - With the explicit consent of the user, we will process health data for the specific purposes listed below: - Create the CareLink™ Personal account, in order to upload device data and generate CareLink™ Personal reports; - aggregate health data in a way that does not directly identify users. We will use this information to generate internal reports for further research and to develop new products and services for diabetes management and improve existing products and services and/or develop materials presented to doctors and public entities and at conferences to showcase product performance and enable Medtronic to improve education, training, and support programs; - where applicable, in order to enable the linking of your CareLink™ Personal account to the CareLink™ account used by your healthcare professional in the context of medical treatment” (art. 83, par. 2 lett. a) of the Regulation);

- “culpable nature of the alleged violation, which, according to the wording of the challenge, would lack sufficient information. Such alleged insufficiency, even if deemed to exist, could only amount to mere negligence on the part of Medtronic” (art. 83, par. 2 lett. b) of the Regulation);

- “Medtronic believes that the formulation of consent for the processing of personal data within the HPS functionality is sufficiently clear and that the processing in question is entirely legitimate and compliant with Articles 5(1)(a), 7, 9, 12, and 13 of the GDPR. However, as mentioned in paragraph 3.2(a)(iv) above, in order to address the Authority's concerns regarding the information contained in the privacy notice concerning the legal basis for processing, Medtronic has further updated its privacy notice to ensure even greater transparency” (art. 83, par. 2 lett. c) of the Regulation);

- “Medtronic has always complied with the obligations imposed on it under Articles 25 and 32 of the GDPR. Thus, at the stage of obtaining consent from the user/patient for the sharing of data with healthcare professionals,

****The principles of privacy by default and privacy by design****

(Article 25 of the GDPR) must be considered respected, as the provision of consent is not a pre-selected option, and the sharing of data could not occur in the absence of prior consent from the data subject” (Article 83, paragraph 2 letter d) of the Regulation);

- “Medtronic has not previously committed and/or notified any violation of the type subject to the current proceedings. This, in addition to having independent mitigating value, constitutes an additional element of evidence of the adequacy of Medtronic's organizational structure concerning the protection of personal data for which it is the data controller” (Article 83, paragraph 2 letter e) of the Regulation);
- “Also in relation to the existence of this element and its mitigating relevance, Medtronic has immediately made itself fully available to the Authority in order to understand and remedy the violation, promptly providing all the information requested in a comprehensive and transparent manner, and proposing from the outset to implement remedial measures” (Article 83, paragraph 2 letter f) of the Regulation);
- “The processing in question concerns data attributable to the genus “health data” (i.e., data related to the use of medical devices associated with CareLink™ Personal). However, it is noted that only the data collected from the user's device (e.g., measurements and parameters recorded by the device itself) are shared with the user's healthcare professional following the connection of the user's CareLink™ Personal account with the healthcare professional's HPS account; no other data or information, such as data, notes, or information manually uploaded by the user to their CareLink™ Personal account, are shared with the healthcare professional” (Article 83, paragraph 2 letter g) of the Regulation);
- “(...) the specific details regarding the functionality of linking the patient's CareLink™ Personal with that of the healthcare professional (in which, in the opinion of this Authority, the violation lies) have been communicated by Medtronic in a transparent, comprehensive, and timely manner” (Article 83, paragraph 2 letter h) of the Regulation).

The Company, therefore, considering the alleged violations to be non-existent, has requested, in the event of a different opinion from the Authority, to consider such violations as “minor” “in the sense referred to in Recital 148 of the GDPR” and to consider “that the corrective measure that best fits the case at hand, if there were to be one, is that of a reprimand.”

****4. Outcome of the investigative activity****

****4.1 The violation of personal data pursuant to Article 33 of the Regulation****

In relation to the violation of personal data, pursuant to Article 33 of the Regulation, it is preliminarily observed that:

- for “personal data” is meant “any information relating to an identified or identifiable natural person (‘data subject’);” an identifiable natural person is one who can be identified directly or indirectly, with particular reference to an identifier such as a name (...) and for “health data” “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information concerning their health status” (Article 4, paragraph 1, nos. 1 and 15 of the Regulation);
- Recital 35 of the Regulation specifies that health data “includes information about the natural person collected during their registration to receive health care services;” “a number, symbol, or specific element assigned to a natural person to uniquely identify them for health purposes;”
- personal data must be “processed lawfully, fairly, and transparently” (principle of “lawfulness, fairness, and transparency”) and “in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage (principle of “integrity and confidentiality”)” (Article 5, paragraph 1, letter a) and f) of the Regulation);
- the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons (Article 32 of the Regulation);
- the regulation on personal data protection provides – in the health sector – that information about health status can only be communicated to the data subject and can be communicated to third parties only on the basis of an appropriate legal basis or at the request of the data subject itself, prior written delegation from the latter (Article 9 of the Regulation);

Given the above, in light of the definition of personal data recalled above, email addresses are attributable to this notion (see regarding the attribution of the email address to the notion of personal

data, provision of June 25, 2002, web doc no. 29864).

Furthermore, with regard to the case at hand, the information subject to the notification, contained in the aforementioned email, although referred to a service communication, being addressed to users of the MiniMed Mobile app located in Italy, which connects - via Bluetooth - the MiniMed™ insulin pump to the user's smartphone, constitutes personal data related to health.

Indeed, this system is intended for individuals who wish to actively manage their diabetes with simplicity and safety, through the MiniMed™ insulin pump that sends data to the aforementioned smartphone application (see numerous provisions from the Authority on this point, including: provision of January 9, 2020, no. 1, web doc no. 9261234; provision of September 16, 2021, no. 328, web doc no. 9722297; provision of May 13, 2021, no. 206, web doc no. 9688020; provision of April 28, 2022, no. 164, web doc no. 9779057; provision of July 7, 2022, no. 242, web doc no. 9809998; provision of January 11, 2023, no. 7, web doc no. 9861356).

The fact that among the recipients there may be not only patients but also their caretakers does not lead to a different qualification of such information as belonging to the special categories of data, given that the content of the email unequivocally referred to the presence of a diabetic condition and that the addresses of the recipients were those provided by the patients. It is also noted that the same Company, in the notification of the breach, qualified such information as health-related.

In relation to the principle of integrity and confidentiality under Article 5, paragraph 1, letter f) and the security obligations under Article 32 of the Regulation, in this case, the technical and organizational measures adopted by the Company were not adequate to ensure a level of security appropriate to the risk, considering the personal data breach that was notified by the data controller and the significant number of email addresses (and therefore recipients) contained in a single notification (see paragraph 6.2 of the Guidelines 01/2021 “on examples regarding the notification of a personal data breach,” adopted on January 14, 2021; provision of May 13, 2021, web doc no. 9688020; provision of September 16, 2021, web doc no. 9722297; and provision of July 7, 2022, cited).

Moreover, the same Company, during the investigation, planned the adoption of further organizational measures specifically to prevent the recurrence of similar events. Therefore, the sending of communications via email notifications to a multiple number of recipients (of which 732 in Italy), who were included in the carbon copy (c.c.) field, has, in fact, without justified reason and in the absence of an appropriate legal basis, mutually revealed to the recipients of the communications the health status of the other interested parties, thus constituting a processing of health data in violation of Articles 5, paragraph 1 letters a) and f), 9, and 32 of the Regulation.

4.2. Further Violations

In relation to the sharing of the patient's clinical data with the healthcare professional through the “Health Partner Share” functionality, which allows the patient to link their CareLink™ Personal account with that of the healthcare professional treating them, and to the contestation regarding the violation of informational obligations and the acquisition of the relevant consent for the processing of personal data carried out by the Company at the time of the aforementioned linking, it is observed that: personal data must be processed in compliance with the applicable principles of processing, and of “accountability,” under which the data controller must be able to demonstrate compliance with the aforementioned principles, with logical reasoning, concrete evidence, and proactive behaviors (Article 5, paragraphs 1 and 2, and Article 24 of the Regulation); in this context, the aforementioned principle of lawfulness is particularly relevant, under which every processing of personal data must be based on a specific legal basis (Article 5, paragraph 1, letter a) of the Regulation); in cases where the condition of lawfulness is represented by consent, it must be free, specific, informed, and unambiguous regarding the processing of personal data concerning the data subject (Recitals 32, 42, and 43, Articles 5, 6, paragraph 1, letter a) and 7 of the Regulation and Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted by the European Data Protection Board on May 4, 2020; C-673/17 judgment of October 1, 2019, and C-61/19 judgment of November 11, 2020); consent, to be freely given, must be informed; for it to be so, “the data subject should be made aware at least of the identity of the data controller and the purposes of the processing for which the personal data are intended” (Article 7 of the Regulation and

Recital 42; see also paragraphs 3.3.1 and 3.3.2 and in particular point 64 of the Guidelines 5/2020 on consent under Regulation (EU) 2016/679, version 1.1 adopted on May 4, 2020, according to which “to obtain valid consent, at least the following information [must be provided to the data subject]: i. the identity of the data controller; ii. the purpose of each of the processing operations for which consent is sought; iii. what (types of) data will be collected and used; iv. the existence of the right to withdraw consent (...);” personal data must also be processed in compliance with the principle of transparency (Article 5, paragraph 1 letter a) of the Regulation) by providing the data subjects in advance with the information referred to in Article 13 of the Regulation, in the case of data collected directly from them, or pursuant to Article 14, in the case of data collected from third parties. This principle requires that the information and communications related to the processing of personal data be provided in a concise, transparent, intelligible, and easily accessible form, using clear and plain language (Recitals 39, 58, and Article 12 of the Regulation);

****According to the Guidelines on Transparency pursuant to Regulation 2016/679, adopted on November 29, 2017, in the amended version adopted on April 11, 2018,**** “the element of ‘easy accessibility’ implies that the data subject should not be forced to search for information, but rather it should be immediately clear to them where and how this information is accessible, for example, because it is provided directly, a link directs them to it, or the information is clearly marked, or because the information is configured as a response to a question in natural language (for example, in a layered online privacy statement/information, in FAQs, through contextual pop-ups that activate when the data subject fills out an online form, or, in an interactive digital context, through a chatbot interface, etc.)” (par. 11 and also par. 33-40);

****In the context of applications that are capable of collecting large amounts of data from the device (for example, data stored by the user and data from various sensors, including geolocation),**** the end user has the right to know what types of personal data are being processed, for what purposes they are intended to be used, and on what legal bases (see Opinion 02/2013 (WP202), on applications for smart devices adopted on February 27, 2013, by the “Art. 29” Working Group);

****In compliance with the principle of transparency, both the purposes and the corresponding legal bases for processing must be clear before the processing begins.****

****Having said that, from the documentation on file, it emerges that the “privacy notice,” even in the version of July 2022, although modified compared to the previous version of September 24, 2020, does not provide clear information, in particular, regarding the processing of personal data carried out during the linking process of the patient’s and healthcare professional’s CareLink™ Personal accounts, should the former wish to use the HPS function.****

****This is considering that, in relation to the processing in question as described above, such linking—carried out through the technical functionalities made available by the Company—entails a communication of personal data between different data controllers, for which the legal basis on which it is based must be indicated in the aforementioned notice, involving a new operation of processing personal data, including health data, by healthcare professionals, as independent controllers.****

****In fact, the notice, in the September 2020 version, does not provide any information in this regard, while in the July 2022 version, it merely informs the patient that “Should you choose to share personal data with healthcare providers in the context of medical treatment or with other parties external to Medtronic, they will be solely responsible for the use or further processing of the personal data.”****

****Moreover, the aforementioned information is not provided even when the patient is about to make the aforementioned link.****

****Indeed, on the final screen of the account linking, the patient is only informed that by pressing the “accept” button, they authorize Medtronic to carry out the aforementioned linking; on the same screen, the patient is informed that if they are interested in receiving more information about the processing of personal data by Medtronic, they can consult the privacy notice accessible directly from the same page through a hypertext link, which lacks indications regarding the legal basis on which this processing operation is based.****

****Therefore, both in the document containing the notice prepared in September 2020 and in the updated document in July 2022, the Company has failed to provide the informative element regarding the legal basis under which the aforementioned communication of personal data is made; this constitutes a violation of the aforementioned principles of fairness and transparency referred to in Articles 5, par. 1 lett. a), as well as Articles 12 and 13 of the Regulation.****

****Only in the latest version of the document titled "Privacy Notice," which came into effect on January 20, 2023, is the legal basis of consent for the processing of health data indicated "(...), in order to enable the linking of your CareLink™ Personal account to the CareLink™ account used by your healthcare professional in the context of medical treatment."****

****5. Conclusions****

****In light of the evaluations mentioned above, considering the statements made by the data controller during the investigation and noting that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor," the elements provided by the data controller in the aforementioned defensive memorandum and during the investigation, although deserving of consideration, do not allow for a complete overcoming of the observations notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for by Article 11 of the Guarantor's Regulation No. 1/2019 apply.****

****For these reasons, the preliminary assessments of the Office are confirmed, and the illegality of the processing of personal data carried out by Medtronic Italia S.p.a. is noted, in violation of Articles 5, par. 1, lett. a), f), 9, 12, 13, and 32 of the Regulation.****

Regulation. The violation of the aforementioned provisions also makes applicable, pursuant to Article 58, paragraph 2, letter i), the administrative sanction provided for by Article 83, paragraphs 4 and 5 of the Regulation, in accordance with Articles 58, paragraph 2, letter i), and 83, paragraph 3, of the same Regulation. In this context - considering, in any case, that the conduct has exhausted its effects, taking into account that the Company has declared that, in addition to retraining the personnel involved in sending emails, it intends, in reviewing the adopted procedures, to use a new automated tool to prevent the occurrence in the future of the described incident, also implementing further controls before sending any email notification and acknowledging that the same Company has integrated the information notice, which came into effect in January 2023, in the terms described above - the conditions for the adoption of measures, of a prescriptive or prohibitory nature, pursuant to Article 58, paragraph 2, of the Regulation do not exist.

6. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code). The Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019).

In this case, the Company has engaged in two distinct conducts, which must be considered separately for the purpose of quantifying the administrative sanction to be applied.

6.1. The conduct referred to in paragraph 4.1 Considering that the violation of the provisions cited in the previous paragraph 4.1, concerning the sending of communications via email notifications to multiple recipients, who were included in the carbon copy (c.c.) field, in the absence of a suitable legal basis, occurred as a result of a single conduct (same treatment or related treatments), Article 83,

paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Considering that, in this case, the most serious violation concerns Articles 5, paragraph 1, letters a) and f) and 9 of the Regulation, the total amount of the sanction is to be quantified up to 4% of the turnover if the balance, as in the case at hand, exceeds the amount of 20,000,000 euros (maximum so-called “static” amount).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation. With specific regard to the violations committed by the Company, it is noted that the level of severity has been considered medium, taking into account the number of affected individuals involved, the duration of the violation as well as the categories of personal data concerned (health data) and the unintentional nature (Article 83, paragraph 2, letters a) and b) of the Regulation; see European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

Furthermore, the additional elements provided for by Article 83, paragraph 2 of the Regulation have been considered, in particular that: no complaints or reports have been received by the Authority regarding the incident (Article 83, paragraph 2, letter k) of the Regulation); the Company has taken into account the observations raised by the Office by revising the adopted procedures in order to reduce the replicability of the incidents that occurred.

In light of the aforementioned elements, assessed in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction at 250,000 euros (two hundred fifty thousand) for the violation of Articles 5, paragraph 1, letters a) and f) and 9 of the Regulation. Given the particular sensitivity of the data processed, it is also deemed that the accessory sanction of publication on the Authority's website of this provision, provided for by Article 166, paragraph 7 of the Code and Article 16 of the Regulation of the Authority No. 1/2019, should be applied. It is finally noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

6.2. The conduct referred to in paragraph 4.2 The violation of the provisions cited in the previous paragraph 4.2, arising from the failure to indicate - both in the document containing the information prepared in September 2020 and in the one updated in July 2022 - the informational element relating to the legal basis under which the communication of personal data to healthcare professionals is made, occurred as a result of a further single conduct (same treatment or related treatments). In this case, the violation of Articles 5, paragraph 1, letter a), 12 and 13 of the Regulation entails the application of Article 83, paragraph 5 of the Regulation according to which the amount of the sanction is to be quantified up to 4% of the turnover, if the...

balance sheet, as in the case at hand, exceeds the amount of euro 20,000,000 (maximum so-called “static” fine). The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for in Article 83, paragraph 2, of the Regulation.

With specific regard to the violations committed by the Company, it is noted that the level of severity has been considered low, given that the violation concerned only the absence of one specific informational element referred to in Article 13 of the Regulation and the unintentional nature of the conduct (Article 83, paragraph 2, letters a) and b) of the Regulation; see European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

Finally, the additional elements provided for in Article 83, paragraph 2 of the Regulation have been considered, in particular that:

- no complaints or reports have been received by the Authority regarding the incident (Article 83, paragraph 2, letter k) of the Regulation);
- the Company has taken steps to integrate the information (Article 83, paragraph 2, letter c) of the Regulation) and has demonstrated a high degree of cooperation with the Authority during the

investigation (Article 83, paragraph 2, letter f) of the Regulation).

In light of the aforementioned elements, assessed in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction at euro 50,000 (fifty thousand) for the violation of Articles 5, paragraph 1, letter a), 12 and 13 of the Regulation.

Given the particular sensitivity of the data processed, it is also considered that the accessory sanction of publication on the Authority's website of this provision, as provided for in Article 166, paragraph 7 of the Code and Article 16 of the Authority's Regulation No. 1/2019, should be applied.

It is finally noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by Medtronic Italia S.p.a. for the violation of Articles 5, paragraph 1, letters a) and f), 9, 12, 13 and 32 of the Regulation, as stated in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, Medtronic Italia S.p.a., with registered office in Milan, via Varesina, 162, postal code 20156, Tax Code and VAT number 09238800156, represented by the legal representative pro tempore, to pay the total sum of euro 300,000 (three hundred thousand) as an administrative pecuniary sanction for the violations indicated in this provision; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of each of the imposed sanctions.

ORDERS

the aforementioned Medtronic Italia S.p.a., in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of euro 300,000 (three hundred thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent enforcement acts pursuant to Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file a judicial appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 8, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE DEPUTY SECRETARY GENERAL

Filippi